

AWS Learning Notes

Complete IAM + Getting Started with EC2

Part 1: IAM - users, groups, policies, roles, MFA, access keys, security tools, SCPs and permissions boundaries. **Part 2: EC2** - instances, AMIs, key pairs, security groups, launching and connecting.

PART 1: IAM

1. Core Building Blocks

Item	What it is
Root user	Account owner. Unlimited power. Lock it away with MFA.
IAM user	Long-term identity (console password and/or access keys) for a person or app.
Group	Set of users. Attach policies to the group, not to each user. Groups cannot be nested.
Role	Temporary identity assumed by users, AWS services or other accounts. No permanent keys.
Policy	JSON document that allows or denies actions.

IAM is a **global** service (not tied to a Region) and is **free**.

2. Working as an IAM User (without Root)

- Create an **account alias** (IAM dashboard > Account alias) so the sign-in URL is `https://alias.signin.aws.amazon.com/console` instead of the account ID.
- Sign in by choosing **IAM user**, then entering the account ID or alias, user name and password.
- Give the IAM user the permissions it needs (e.g. AdministratorAccess for an admin user), enable **MFA**, and use it for all daily work.
- Keep root for the few tasks only root can do: close the account, change the root email/password, restore IAM permissions if locked out, and some billing and support-plan changes.

3. Policies in Depth

Types: AWS-managed (ready-made, e.g. AmazonS3ReadOnlyAccess), customer-managed (yours, reusable), and inline (embedded in one user, group or role; avoid unless needed). Identity-based policies attach to users, groups and roles. Resource-based policies attach to a resource (e.g. an S3 bucket policy).

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "AllowReadMyBucket",
    "Effect": "Allow",
    "Action": ["s3:GetObject", "s3:ListBucket"],
    "Resource": [
      "arn:aws:s3:::my-bucket",
      "arn:aws:s3:::my-bucket/*"
    ],
    "Condition": {
      "IpAddress": {"aws:SourceIp": "203.0.113.0/24"}
    }
  }]
}
```

Field	Meaning
Effect	Allow or Deny
Action	API operations, written service:Action. Wildcards allowed (s3:Get*).
Resource	What the action applies to, identified by ARN. * means all.
Condition	Optional extra rules: source IP, MFA present, tags, time, Region.
Principal	Used only in resource-based and trust policies: who the statement applies to.

Evaluation logic

- 1 Default is **implicit deny**.
- 2 Any **explicit Deny** in any applicable policy wins immediately.
- 3 Otherwise an **Allow** is needed. Several policies combine as a union of Allows.
- 4 Permissions boundaries and SCPs act as limits: an action must be allowed by the identity policy **and** not blocked by these.

4. Roles, Trust Policies and STS

A role has two parts: a **permissions policy** (what it can do) and a **trust policy** (who may assume it). Assuming a role gives **temporary credentials** from **STS** (Security Token Service) that expire automatically.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Principal": {"Service": "ec2.amazonaws.com"},
    "Action": "sts:AssumeRole"
  }]
}
```

- **Common uses:** an EC2 instance reading S3, a Lambda function writing logs, cross-account access, federated users.
- **Instance profile:** the wrapper that lets EC2 use a role. The console creates it for you when you attach an IAM role to an instance.
- Roles remove the need to store access keys on servers.

5. MFA, Passwords and Access Keys

- **MFA** adds a second factor (authenticator app, passkey/security key, hardware token). Enable it on root and on every user.
- **Password policy** (IAM > Account settings): minimum length, character types, expiry, and prevent reuse.
- **Access keys** (access key ID plus secret) are for CLI/SDK use. The secret is shown only once. Each user can have up to two, which allows rotation.
- Rotate keys regularly, deactivate then delete unused ones, and **never put them in code or GitHub**. Prefer roles whenever possible.
- Avoid creating access keys for the root user.

6. IAM Security Tools

Tool	What it tells you
Credential report	Account-wide CSV: every user, password age, MFA status, access key age and last use.
Access Advisor (last accessed)	Per user/role/policy: which services were accessed and when. Use it to remove unused permissions.
IAM Access Analyzer	Finds resources shared outside your account (S3, roles, KMS keys, etc.) and can generate least-privilege policies from CloudTrail activity.
Policy Simulator	Tests whether a user/role would be allowed or denied specific actions without running them.
CloudTrail	Records API calls: who did what, when and from where. Essential for auditing.
IAM Identity Center	Single sign-on across multiple accounts and apps with central user management.

7. Permissions Boundaries and Service Control Policies (SCPs)

Both **limit** what can be granted. Neither grants permissions on its own.

	Permissions boundary	Service Control Policy (SCP)
Applies to	A single IAM user or role	An AWS Organizations account or OU (all users and roles in it, including the account's root user)
Purpose	Cap the maximum permissions an identity can ever have, e.g. when delegating user creation	Set guardrails for whole accounts, e.g. deny use of certain Regions or services
Effective permission	Identity policy AND boundary	Identity policy AND SCP (AND boundary if set)
Does not apply to	-	The Organizations management account

```

{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Deny",
    "NotAction": ["iam:*", "organizations:*", "support:*"],
    "Resource": "*",
    "Condition": {"StringNotEquals": {
      "aws:RequestedRegion": ["ap-south-1", "eu-north-1"]
    }}
  }]
}  <-- example SCP: only allow two Regions

```

8. IAM Best Practices Checklist

- MFA on root; do not use root daily; no root access keys.
- Use groups for permissions, roles for services and cross-account access.
- Apply least privilege; review with Access Advisor and Access Analyzer.
- Set a password policy; rotate or delete old access keys.
- Turn on CloudTrail; review the credential report periodically.
- Never commit secrets to GitHub.

PART 2: EC2 (Elastic Compute Cloud)

EC2 provides resizable virtual servers (instances) in the cloud. It is IaaS: AWS manages the hardware, you manage the OS, software and security settings on the instance.

1. Key Concepts

Concept	Meaning
Instance	A running virtual server.
AMI	Amazon Machine Image: template with OS and software (e.g. Amazon Linux, Ubuntu, Windows). Region-specific.
Instance type	CPU, memory, network size. Name format: family + generation + size, e.g. t3.micro.
Key pair	Public/private key for SSH (Linux) or password decryption (Windows). The private key (.pem) can be downloaded only once.
Security group	Stateful virtual firewall on the instance. Allow rules only; all inbound is denied by default and all outbound allowed.
EBS volume	Network disk for the instance (boot volume plus optional extras).
Availability Zone / Subnet	Where in the Region the instance runs (inside a VPC subnet).
User data	Script that runs at first boot, useful for installing software automatically.
Instance profile	Attaches an IAM role to the instance.

2. Instance Type Families

Family	Optimised for	Examples
General purpose	Balanced CPU/memory	t3, t4g, m5, m6i
Compute optimised	CPU-heavy work	c5, c6i
Memory optimised	Large in-memory data	r5, r6i, x1
Storage optimised	High disk I/O	i3, d2
Accelerated	GPU / ML	p3, g4

The **t-family** is **burstable**: it earns CPU credits while idle and spends them under load. It is good for learning and light workloads.

3. Launching an Instance (Console)

- 1 EC2 > **Launch instance**. Check the Region first.
- 2 Name it, choose an **AMI** (e.g. Amazon Linux or Ubuntu, Free Tier eligible).
- 3 Choose a **Free Tier eligible instance type** (shown with a label; t2.micro or t3.micro depending on Region).
- 4 Create or select a **key pair** and download the .pem file safely.

- 5 Network settings: create a **security group** allowing SSH (22) from **My IP** only, and HTTP (80) if running a web server.
- 6 Storage: keep the default 8 GiB gp3 boot volume.
- 7 Optional: expand Advanced details to add **user data** or an IAM instance profile.
- 8 Launch, wait for **Running** and **2/2 checks passed**.

```
#!/bin/bash
# example user data: install and start nginx on Amazon Linux
dnf install -y nginx
systemctl enable --now nginx
```

4. Connecting to an Instance

- **EC2 Instance Connect** (browser): select the instance > Connect. Easiest for beginners, no key file handling.
- **SSH from a terminal**: restrict key permissions first, then connect with the public IP or DNS name.
- **Session Manager** (Systems Manager): no open port 22 needed, but requires an IAM role on the instance.

```
chmod 400 my-key.pem
ssh -i my-key.pem ec2-user@<public-ip>      # Amazon Linux
ssh -i my-key.pem ubuntu@<public-ip>        # Ubuntu
```

5. IP Addresses

- **Private IP**: fixed for the instance's life inside the VPC.
- **Public IP**: auto-assigned but **changes** when the instance is stopped and started.
- **Elastic IP**: a static public IP you own. It costs money while not attached to a running instance (and public IPv4 addresses are charged), so release it when unused.

6. Instance States and Billing

Action	Effect	Billing
Stop	Instance shuts down; EBS volumes remain	No compute charge; EBS storage still charged
Start	Boots again, usually on new hardware with a new public IP	Compute charge resumes
Reboot	Restarts the OS, same hardware and IP	No change
Hibernate	Saves RAM to disk, resumes later (supported types only)	Storage charged
Terminate	Instance deleted permanently; boot volume deleted by default	Charges stop (extra volumes may remain)

7. Purchasing Options

Option	Best for
On-Demand	Pay per second/hour, no commitment. Short or unpredictable workloads, learning.
Savings Plans / Reserved	1 or 3 year commitment for a steady workload, large discount.
Spot	Spare capacity at big discounts; can be interrupted. Fault-tolerant or batch jobs.
Dedicated Host / Instance	Physical server dedicated to you, for licensing or compliance needs.

8. Security Group Basics

- **Stateful**: if inbound traffic is allowed, the reply is automatically allowed out.
- Allow rules only; you cannot write deny rules (use NACLs at the subnet level for that).
- Never open SSH (22) or RDP (3389) to 0.0.0.0/0 in real use. Restrict to your IP.

- A security group can be attached to many instances, and an instance can have several groups.

9. Cleanup and Cost Checklist

- Stop or terminate instances when finished with practice.
- Delete unattached EBS volumes and old snapshots.
- Release unused Elastic IPs.
- Keep a billing budget alert active.
- Do not leave .pem files or access keys in GitHub repos.

10. Next Topics

- EC2 + IAM role: let an instance read S3 with no access keys.
- EBS snapshots and AMIs (create your own image).
- Elastic Load Balancer and Auto Scaling.
- VPC networking, then AWS CLI in CloudShell.